

Table of Contents

Status da revisão: Edição de revisão controlada. Requer validação humana de terminologia, significado, links, formatação, acessibilidade e atualidade técnica antes da publicação final.

SÉRIE PRÁTICA DE CIBERSEGURANÇA, PRIVACIDADE E CONFORMIDADE

CIS Critical Security Controls v8.1

Implementação prática, medição, evidências e ferramentas de código aberto

Manual de trabalho para gestores, analistas juniores, estudantes, profissionais em transição de carreira, avaliadores e equipes de segurança

Alberto (Al) Leiva

Primeira edição • Julho de 2026

Conteúdo: 18 Controles • 153 Salvaguardas • IG1, IG2 e IG3 • medição • evidências • ferramentas • guia para gestores • laboratórios • preparação profissional

Aviso de publicação e uso

Autor: Alberto (Al) Leiva

Edição: Primeira edição, julho de 2026

Este manual educacional independente não é uma publicação, certificação, acreditação, relatório de auditoria, opinião jurídica ou garantia de segurança ou conformidade emitida pelo Center for Internet Security. CIS Controls e CIS Benchmarks são marcas do Center for Internet Security. Consulte os recursos oficiais do CIS para obter o conteúdo exato e a orientação vigente.

Os CIS Controls representam boas práticas de cibersegurança. Eles não substituem leis, regulamentos, contratos, requisitos setoriais, avaliações de risco ou responsabilidades de gestão aplicáveis. Um mapeamento demonstra relações entre estruturas; não comprova automaticamente a conformidade com outra estrutura.

Uso ético e autorizado

Utilize ferramentas técnicas somente em ativos, redes, aplicações, contas de nuvem, repositórios e dados que você possui ou para os quais recebeu autorização específica por escrito. Em laboratórios, utilize informações sintéticas e sistemas isolados.

Prefácio

Introdução prática à defesa cibernética priorizada e à medição baseada em evidências.

Os CIS Controls transformam necessidades defensivas comuns em Salvaguardas específicas. Sua principal força é a priorização prática: conhecer os ativos, controlar software e dados, proteger configurações e identidades, gerenciar vulnerabilidades e registros, preparar-se para interrupções e ataques e testar se as defesas funcionam.

A versão 8.1 é uma atualização iterativa da versão 8. Ela realinhou os mapeamentos ao NIST CSF 2.0, ampliou definições de termos reservados, revisou classes de ativos e mapeamentos de Salvaguardas, corrigiu questões menores, esclareceu determinadas Salvaguardas e incorporou a função Governar aos mapeamentos. Os 18 Controles e as 153 Salvaguardas permanecem como estrutura central.

A instalação de uma ferramenta não equivale à implementação de um controle. Uma implementação efetiva exige escopo definido, populações completas, configuração segura, evidência operacional, responsáveis capacitados, tratamento de exceções, medição, correção e novos testes. Gestores definem prioridades e recursos; analistas tornam essas decisões confiáveis por meio de inventários e evidências precisos.

Como usar este manual

- Gestores devem começar pelos capítulos 1–5 e 24–25.
- Analistas juniores devem estudar os 18 capítulos de Controles, o método de medição, as ferramentas, o laboratório e o capítulo de entrevistas.
- Equipes técnicas devem relacionar cada Salvaguarda a ativos, dados, responsáveis, procedimentos, configurações, monitoramento, exceções e evidências.
- Avaliadores devem utilizar a especificação oficial de avaliação dos CIS Controls para confirmar entradas, operações, medidas, métricas, premissas e revisões de procedimentos.

Sumário no Word: O arquivo DOCX pode conter um campo nativo de sumário. Após qualquer edição, atualize o campo e selecione a opção para atualizar a tabela inteira.

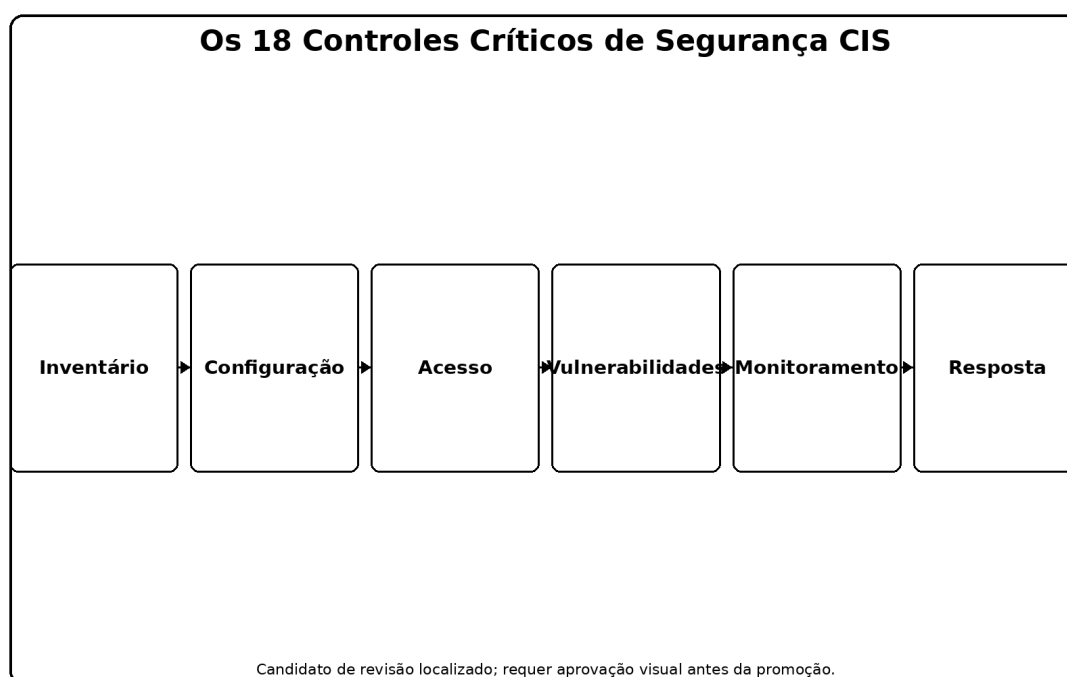
Sumário

1. Fundamentos dos CIS Controls v8.1
2. Grupos de Implementação e priorização
3. Governança, escopo e responsabilidades
4. Medição com a especificação de avaliação do CIS

5. Roteiro de implementação
6–23. Os 18 CIS Controls
6. Ferramentas de código aberto
7. Guia dos CIS Controls para gestores
8. Guia profissional para analistas juniores
9. Laboratório fictício e portfólio
10. Plano de aprendizagem de trinta dias
11. Preparação para entrevistas
12. Modelos, glossário, índice e referências

1. Fundamentos dos CIS Controls v8.1

A versão atual, sua estrutura, finalidade e limitações.



Os Controles organizam 153 Salvaguardas em um programa defensivo prático.

Figura 1. Os 18 CIS Critical Security Controls

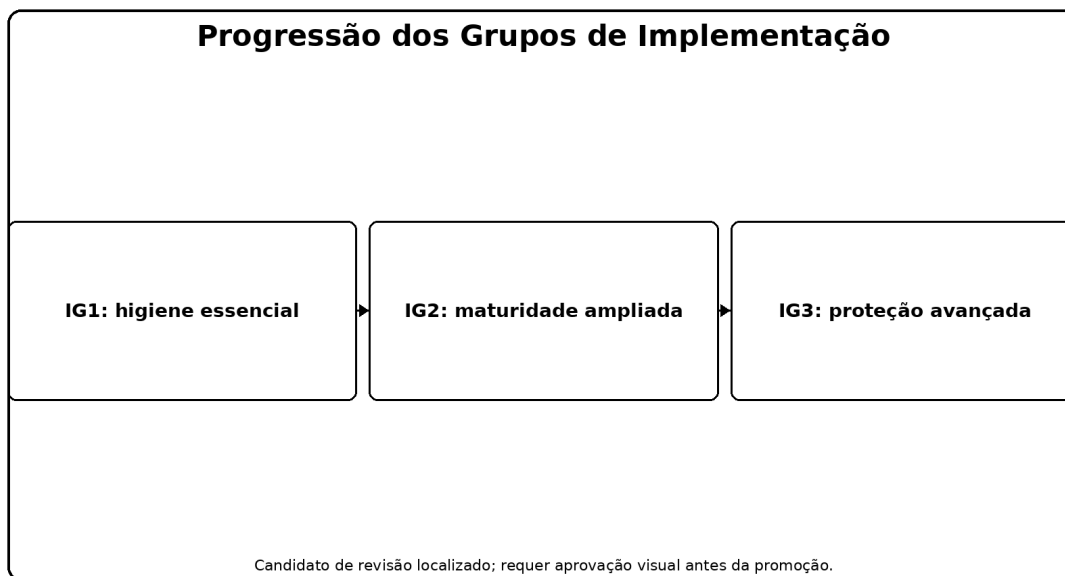
- Os CIS Controls v8.1 foram publicados em junho de 2024.

- Os Controles são boas práticas priorizadas para defender sistemas e redes contra ataques prevalentes.
- A estrutura contém 18 Controles e 153 Salvaguardas.
- As Salvaguardas são relacionadas a classes de ativos, funções de segurança e Grupos de Implementação.
- A versão 8.1 alinha o mapeamento ao NIST CSF 2.0 e inclui a função Governar.
- Existem mapeamentos oficiais para várias estruturas, mas cada requisito aplicável deve ser verificado separadamente.

Camada	Finalidade
Controle	Resultado defensivo amplo, como inventário de ativos ou resposta a incidentes.
Salvaguarda	Ação específica que pode ser atribuída, implementada e medida.
Classe de ativo	Tipo de elemento afetado, como dispositivos, software, dados, redes, usuários ou documentação.
Função de segurança	Mapeamento para Governar, Identificar, Proteger, Detectar, Responder ou Recuperar.
Grupo de Implementação	Priorização recomendada de acordo com o perfil de risco e os recursos.
Medida de avaliação	Entradas, operações, medidas, métricas e revisão de procedimentos usadas para avaliar uma Salvaguarda.

2. Grupos de Implementação e priorização

Como IG1, IG2 e IG3 ajudam organizações a escolher um ponto de partida realista.



Cada Grupo de Implementação se apoia no grupo anterior; o IG3 contém todas as Salvaguardas.

Figura 2. Progressão dos Grupos de Implementação

Grupo	Salvaguardas	Situação típica	Objetivo
IG1	56	Recursos e experiência de segurança limitados; menor sensibilidade; necessidade elevada de continuidade básica.	Higiene cibernética essencial contra ataques comuns.
IG2	IG1 + 74	Vários departamentos, maior complexidade, informações sensíveis e maior dependência operacional.	Gerenciar riscos e complexidade operacional crescentes.
IG3	IG1 + IG2 + 23 = 153	Especialistas em segurança, dados sensíveis ou regulamentados, serviços críticos e ameaças sofisticadas.	Reduzir o impacto de ataques direcionados e avançados.

- Toda organização deve considerar o IG1 como ponto de partida, conforme a orientação do CIS.
- A seleção do grupo deve considerar sensibilidade dos dados, serviços críticos, exposição a ameaças, obrigações legais e contratuais, tolerância do negócio, tecnologia, pessoal e experiência.
- Um Grupo de Implementação é um mecanismo de priorização; não autoriza ignorar riscos materiais ou requisitos obrigatórios.
- Documente acréscimos, sequência, exceções, aceitação de risco, responsáveis e datas.
- Utilize o CIS Controls Navigator oficial para filtrar as Salvaguardas v8.1 e consultar os mapeamentos.

3. Governança, escopo e responsabilidades

A base de gestão necessária para operar as Salvaguardas de maneira consistente.

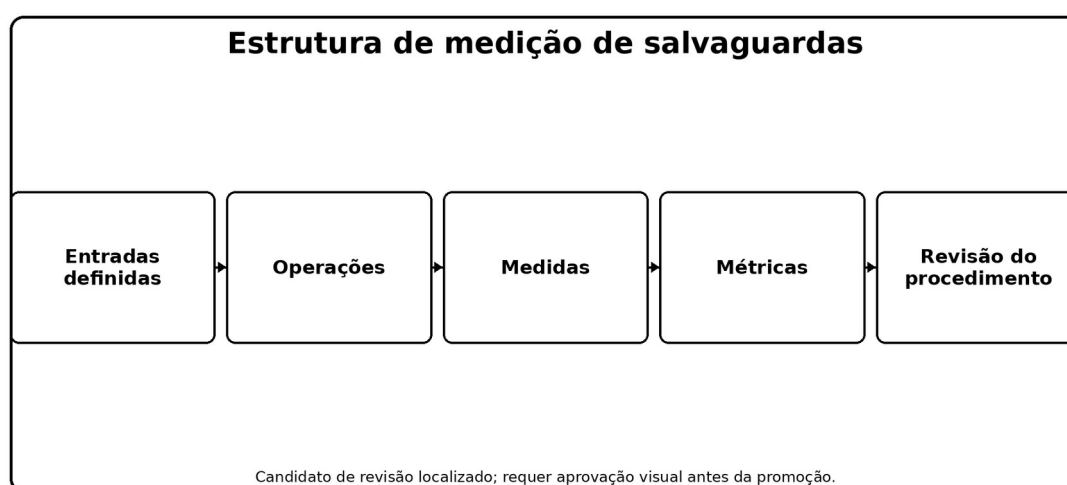
- Defina objetivos de negócio, serviços críticos, dados sensíveis, obrigações legais e contratuais, perfil de ameaças, tolerância ao risco e Grupo de Implementação selecionado.
- Mantenha inventários completos de ativos empresariais, software, dados, contas, sistemas de autenticação, infraestrutura de rede, registros, fornecedores, aplicações e recursos de recuperação.
- Designe um responsável principal para cada Salvaguarda e responsáveis operacionais para cada plataforma ou processo afetado.
- Defina escopo, aplicabilidade, dependências, responsabilidades de prestadores de serviços, exceções permitidas, autoridade de aprovação e gatilhos de revisão.
- Planeje orçamento, pessoas, competências, tecnologia, tempo e gestão de mudanças.
- Defina métricas e relatórios antes da implementação para tornar visíveis a cobertura e as falhas.
- Opere um ciclo de governança: priorizar, implementar, medir, corrigir, testar novamente e melhorar.

Função	Decisão ou responsabilidade
Patrocinador executivo	Direção, tolerância ao risco, orçamento, escalonamento e responsabilidade final.
Responsável pelo Controle	Desenho da Salvaguarda, escopo, procedimento, medição, exceções e melhoria.
Responsável pelo ativo ou serviço	Inventário preciso, uso aprovado, configuração, impacto de negócio e remediação.
Operações de segurança	Monitoramento, alertas, investigação, resposta e evidências.
TI e engenharia	Implementação, gestão de mudanças, correções, configuração e recuperação.
GRC ou analista	Mapeamento, evidências, medição, achados,

Função	Decisão ou responsabilidade
Auditoria interna ou avaliador	acompanhamento de ações e relatórios. Critérios objetivos, testes, limitações e conclusões.
Prestador de serviços	Controles contratados, evidências, incidentes, mudanças e apoio à saída.

4. Medição com a especificação de avaliação do CIS

Um método repetível para determinar se as Salvaguardas estão implementadas.



A especificação oficial avança de entradas definidas para operações, medidas, métricas e revisão de procedimentos.

Figura 3. Estrutura de medição das Salvaguardas CIS

Elemento	Pergunta
Metadados da Salvaguarda	Qual é a Salvaguarda exata, a classe de ativo, a função de segurança e o IG?
Dependências	Quais outras Salvaguardas ou populações devem existir primeiro?
Premissas	Qual condição aceita afeta a medição?
Entradas	Quais dados completos e confiáveis são necessários?
Operações	Qual análise deve ser realizada sobre as entradas?
Medidas	Quais contagens, listas, datas, configurações ou resultados são produzidos?
Métricas	Como as medidas são calculadas e

Elemento	Pergunta
	interpretadas?
Revisão de procedimentos	Existe um processo documentado e ele contém os elementos necessários?
• Defina com precisão a Salvaguarda e a população aplicável. • Obtenha as entradas necessárias e valide completude, precisão, atualidade, propriedade e confiabilidade da fonte. • Siga as operações oficiais de medição ou documente um método equivalente e confiável. • Preserve os cálculos das medidas e a população de exceções subjacente, não apenas uma porcentagem. • Avalie se a Salvaguarda está implementada e opera adequadamente. • Atribua correções para cobertura ausente, configuração inadequada, revisão atrasada, exceções ou dados não confiáveis. • Execute novos testes utilizando os mesmos critérios e a população atualizada. • Relate escopo, resultado, exceções, limitações, responsável, ação e data.	

5. Roteiro de implementação

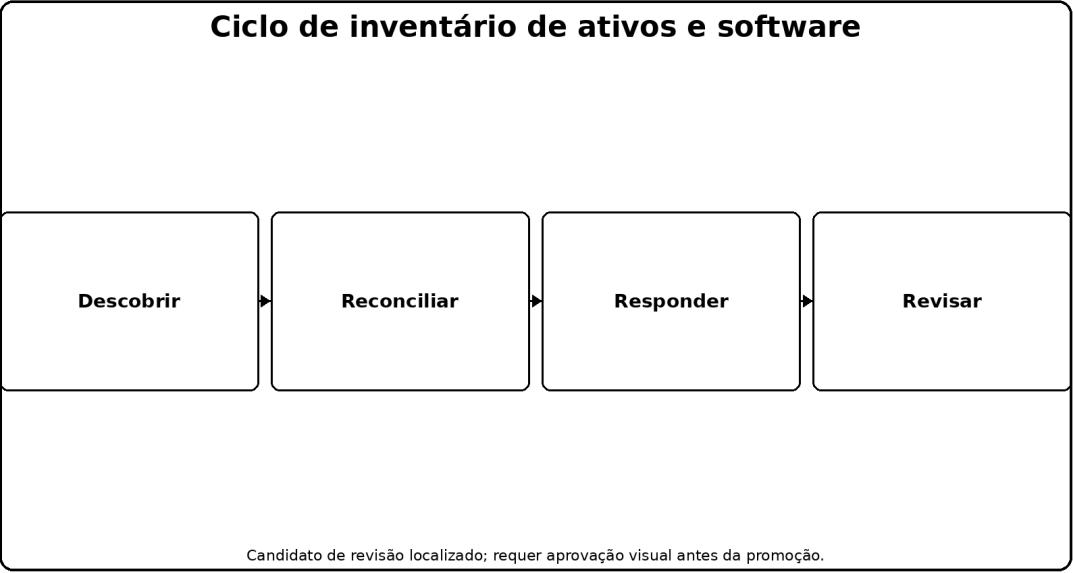
Uma sequência prática que começa com inventários e termina com resiliência testada.

1. Selecione e documente o Grupo de Implementação inicial e os acréscimos necessários.
2. Construa e concilie as populações principais: ativos, software, dados, contas, sistemas de autenticação, redes, fornecedores, aplicações e registros.
3. Implemente as Salvaguardas do IG1 com responsáveis, procedimentos, métricas de cobertura, exceções e evidências.
4. Proteja identidades e configurações; gerencie vulnerabilidades, e-mail, navegadores, defesas contra malware, cópias de segurança e monitoramento essencial.
5. Exercite resposta a incidentes e recuperação antes de uma emergência real.
6. Meça cada Salvaguarda aplicável utilizando entradas confiáveis e operações repetíveis.
7. Corrija cobertura incompleta e falhas recorrentes; confirme as correções por meio de novos testes.
8. Expanda para IG2 ou IG3 conforme o risco, as obrigações, a maturidade e a exposição a ameaças.
9. Utilize mapeamentos oficiais para coordenar outras estruturas sem tratar o mapeamento como comprovação automática de conformidade.

Princípio de implementação: Um conjunto menor de Salvaguardas, com escopo completo, operação consistente, medição e melhoria contínua, é mais defensável do que uma lista extensa marcada como concluída sem evidências confiáveis.

6. Controle 1 — Inventário e controle de ativos empresariais

As 5 Salvaguardas, seu significado claro, o enfoque de verificação e exemplos de evidências.



Descoberta, conciliação, resposta e revisão mantêm atualizadas as populações fundamentais.

Figura 4. Ciclo de inventário de ativos e software

Finalidade do Controle: Fortalecer a organização por meio da implementação e medição das Salvaguardas de inventário e controle de ativos empresariais.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
1.1	Estabelecer e manter um inventário detalhado de ativos empresariais	Manter um inventário completo, atualizado e com responsável definido.	Confirmar escopo, população, responsável, frequência, cobertura, exceções, correção e novo teste.	Inventário de ativos, responsáveis, estado de aprovação, descoberta ativa e passiva, registros DHCP/IPAM e tickets de ativos não autorizados.
1.2	Tratar ativos não autorizados	Detectar, investigar e remover, isolar ou autorizar formalmente ativos não autorizados.	Verificar que alertas geram ações rastreáveis e tempestivas.	Alertas, tickets, registros de isolamento, autorizações e evidências de encerramento.
1.3	Utilizar uma	Executar	Confirmar	Configuração de

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
	ferramenta de descoberta ativa	descoberta ativa para identificar ativos conectados e conciliar os resultados com o inventário.	cobertura, programação, exclusões e conciliação.	varredura, resultados, inventário atualizado e exceções aprovadas.
1.4	Utilizar registros DHCP para atualizar o inventário de ativos empresariais	Integrar registros DHCP ao processo de atualização e conciliação do inventário.	Verificar ingestão, frequência, cobertura e tratamento de divergências.	Registros DHCP, integrações, relatórios de conciliação e tickets.
1.5	Utilizar uma ferramenta de descoberta passiva de ativos	Monitorar tráfego ou telemetria para identificar ativos sem gerar varredura ativa.	Confirmar sensores, segmentos cobertos, alertas e conciliação.	Configuração de sensores, resultados, cobertura de rede e atualizações do inventário.

Consulte os CIS Controls v8.1 e a CIS Controls Assessment Specification oficiais para confirmar linguagem exata, classe de ativo, função de segurança, Grupo de Implementação, dependências, entradas, operações, medidas, métricas e revisão de procedimentos.

7. Controle 2 — Inventário e controle de ativos de software

As 7 Salvaguardas, seu significado claro, o enfoque de verificação e exemplos de evidências.

Finalidade do Controle: Fortalecer a organização por meio da implementação e medição das Salvaguardas de inventário e controle de ativos de software.

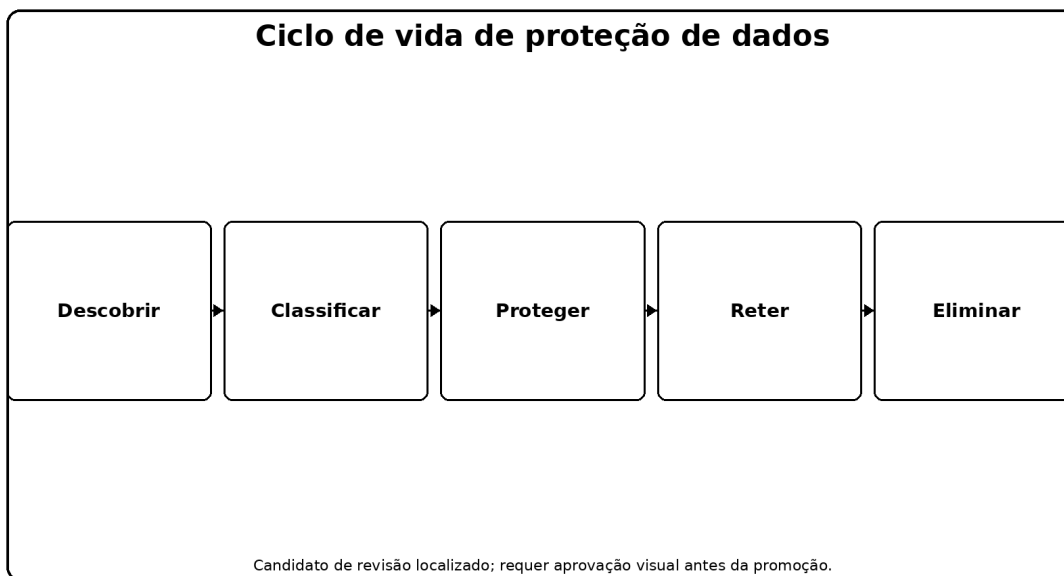
ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
2.1	Estabelecer e manter um inventário de software	Manter um inventário autorizado, atualizado e com responsáveis definidos.	Confirmar escopo, responsável, frequência, cobertura e exceções.	Inventário, versões, responsáveis, estado de suporte e resultados de descoberta.
2.2	Assegurar que o	Identificar	Verificar datas	Inventário,

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
	software autorizado tenha suporte vigente	software sem suporte e atualizá-lo, substituí-lo ou tratá-lo por meio de exceção aprovada.	de fim de suporte e ações corretivas.	boletins de fornecedores, planos de atualização e exceções.
2.3	Tratar software não autorizado	Detectar e remover, bloquear ou aprovar formalmente software não autorizado.	Confirmar que os achados geram ações rastreáveis.	Alertas, tickets, registros de desinstalação, bloqueios e aprovações.
2.4	Utilizar ferramentas automatizadas de inventário de software	Automatizar a detecção de software instalado e conciliá-la com o inventário autorizado.	Verificar cobertura, frequência e tratamento de divergências.	Configuração das ferramentas, resultados e relatórios de conciliação.
2.5	Criar uma lista de software autorizado	Permitir a execução apenas de software aprovado conforme o risco e a necessidade do negócio.	Confirmar política, cobertura, exceções e eventos de bloqueio.	Política de allowlisting, regras, exceções e registros de eventos.
2.6	Criar uma lista de bibliotecas autorizadas	Restringir bibliotecas e componentes carregados a versões aprovadas.	Verificar regras, cobertura e exceções.	Configuração, inventário de bibliotecas, eventos e aprovações.
2.7	Criar uma lista de scripts autorizados	Restringir a execução de scripts aos aprovados e controlados.	Confirmar assinatura, regras, cobertura e exceções.	Repositório aprovado, assinaturas, regras de execução e eventos.

Consulte os recursos oficiais do CIS para confirmar a linguagem e os critérios de avaliação.

8. Controle 3 — Proteção de dados

As 14 Salvaguardas, seu significado claro, o enfoque de verificação e exemplos de evidências.



Descobrir, classificar, proteger, reter e eliminar dados conforme sua sensibilidade e necessidade.

Figura 5. Ciclo de vida da proteção de dados

Finalidade do Controle: Fortalecer a organização por meio da implementação e medição das Salvaguardas de proteção de dados.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
3.1	Estabelecer e manter um processo de gestão de dados	Definir como os dados são identificados, classificados, protegidos, retidos e eliminados.	Confirmar escopo, responsável, revisão e aplicação.	Política, procedimentos, responsáveis e registros de revisão.
3.2	Estabelecer e manter um inventário de dados	Manter inventário de conjuntos de dados, localização, responsável, sensibilidade e uso.	Verificar cobertura, atualidade e conciliação.	Inventário, catálogos, responsáveis e resultados de descoberta.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
3.3	Configurar listas de controle de acesso a dados	Limitar o acesso a dados de acordo com a necessidade e a autorização.	Revisar permissões, funções, exceções e recertificações.	ACLs, funções, aprovações e revisões de acesso.
3.4	Aplicar a retenção de dados	Reter dados durante o período aprovado e exigido.	Comparar regras, sistemas e resultados.	Cronograma de retenção, configurações e registros.
3.5	Eliminar dados de forma segura	Destruir ou apagar dados de modo verificável quando não forem mais necessários.	Confirmar método, cobertura e evidência de eliminação.	Certificados, registros, tickets e testes de apagamento.
3.6	Criptografar dados em dispositivos de usuários finais	Proteger dados armazenados em dispositivos por meio de criptografia gerenciada.	Verificar cobertura, chaves, exceções e estado.	Console de criptografia, inventário, políticas e exceções.
3.7	Estabelecer e manter um esquema de classificação de dados	Definir níveis de sensibilidade e regras de tratamento.	Confirmar critérios, aprovação, comunicação e uso.	Esquema, etiquetas, procedimentos e treinamento.
3.8	Documentar fluxos de dados	Manter diagramas e registros de como os dados são coletados, processados, armazenados e transferidos.	Verificar integridade, atualidade e responsáveis.	Diagramas, registros de tratamento e interfaces.
3.9	Criptografar dados em mídias removíveis	Exigir criptografia para dados armazenados em mídias removíveis.	Confirmar política, configuração e exceções.	Configuração, inventário de mídias e registros.
3.10	Criptografar	Proteger	Revisar	Configuração

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
	dados sensíveis em trânsito	comunicações que transportam dados sensíveis.	protocolos, certificados, cobertura e exceções.	TLS/VPN, certificados e resultados de testes.
3.11	Criptografar dados sensíveis em repouso	Proteger dados sensíveis armazenados em bancos, arquivos e cópias de segurança.	Confirmar algoritmos, chaves, cobertura e exceções.	Configuração, KMS/HSM, inventários e testes.
3.12	Segmentar o processamento e o armazenamento de dados de acordo com a sensibilidade	Separar ambientes e repositórios conforme a classificação e o risco.	Revisar arquitetura, regras e fluxos permitidos.	Diagramas, segmentação, regras e resultados de testes.
3.13	Implementar uma solução de prevenção contra perda de dados	Detectar e controlar transferências não autorizadas de dados sensíveis.	Verificar cobertura, regras, alertas, exceções e resposta.	Políticas DLP, eventos, tickets e métricas.
3.14	Registrar o acesso a dados sensíveis	Manter registros suficientes para identificar quem acessou dados sensíveis e quais ações foram realizadas.	Confirmar fontes, detalhamento, retenção e revisão.	Registros de acesso, SIEM, alertas e revisões.

Consulte os recursos oficiais do CIS para confirmar a linguagem e os critérios de avaliação.

9. Controle 4 — Configuração segura de ativos empresariais e software

As 12 Salvaguardas, seu significado claro, o enfoque de verificação e exemplos de evidências.

Finalidade do Controle: Fortalecer a organização por meio da implementação e medição das Salvaguardas de configuração segura de ativos empresariais e software.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
4.1	Estabelecer e manter um processo de configuração segura	Definir, aprovar, implementar e revisar configurações seguras para ativos e software.	Confirmar padrões, responsáveis, frequência, cobertura e exceções.	Padrões, linhas de base, resultados de avaliação e exceções.
4.2	Estabelecer e manter um processo de configuração segura para a infraestrutura de rede	Aplicar linhas de base seguras a dispositivos e serviços de rede.	Revisar cobertura, mudanças, desvios e correções.	Configurações, backups, comparações e tickets.
4.3	Configurar o bloqueio automático de sessão em ativos empresariais	Bloquear sessões inativas após o período aprovado.	Verificar política, configuração e cobertura.	GPO/MDM, resultados de consulta e exceções.
4.4	Implementar e gerenciar um firewall em servidores	Habilitar e gerenciar regras de firewall em servidores.	Revisar cobertura, regras, mudanças e exceções.	Configuração, inventário, regras e registros.
4.5	Implementar e gerenciar um firewall em dispositivos de usuários finais	Habilitar e gerenciar o firewall local em endpoints.	Confirmar cobertura e estado centralizado.	Console, políticas e relatórios de conformidade.
4.6	Gerenciar de forma segura ativos empresariais e software	Utilizar protocolos e canais administrativos seguros.	Revisar métodos de administração, autenticação e registros.	Configuração, listas de administradores e registros.
4.7	Gerenciar contas padrão em ativos empresariais e software	Desabilitar, alterar ou controlar contas padrão.	Confirmar inventário, estado e exceções.	Resultados de varredura, configuração e tickets.
4.8	Desinstalar ou desabilitar serviços	Reduzir a superfície de ataque	Comparar linhas de base, serviços ativos e	Inventário de serviços, configuração e

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
	desnecessários	removendo serviços não exigidos.	exceções.	aprovações.
4.9	Configurar servidores DNS confiáveis em ativos empresariais	Forçar o uso de resolvedores DNS aprovados.	Verificar configuração, cobertura e desvios.	GPO/MDM, configuração de rede e registros DNS.
4.10	Aplicar bloqueio automático do dispositivo em equipamentos portáteis de usuários finais	Bloquear dispositivos portáteis após inatividade ou tentativas malsucedidas.	Confirmar política, configuração e cobertura.	MDM, políticas e relatórios.
4.11	Aplicar capacidade de apagamento remoto em dispositivos portáteis de usuários finais	Permitir apagamento remoto gerenciado quando o risco exigir.	Verificar cobertura, autorização e testes.	Console MDM, procedimentos e registros de testes.
4.12	Separar espaços de trabalho empresariais em dispositivos móveis de usuários finais	Separar dados e aplicações empresariais dos pessoais.	Revisar perfis, políticas e cobertura.	Configuração MDM/MAM, inventário e relatórios.

Consulte os recursos oficiais do CIS para confirmar a linguagem e os critérios de avaliação.

10. Controle 5 — Gestão de contas

As 6 Salvaguardas, seu significado claro, o enfoque de verificação e exemplos de evidências.

Finalidade do Controle: Fortalecer a organização por meio da implementação e medição das Salvaguardas de gestão de contas.

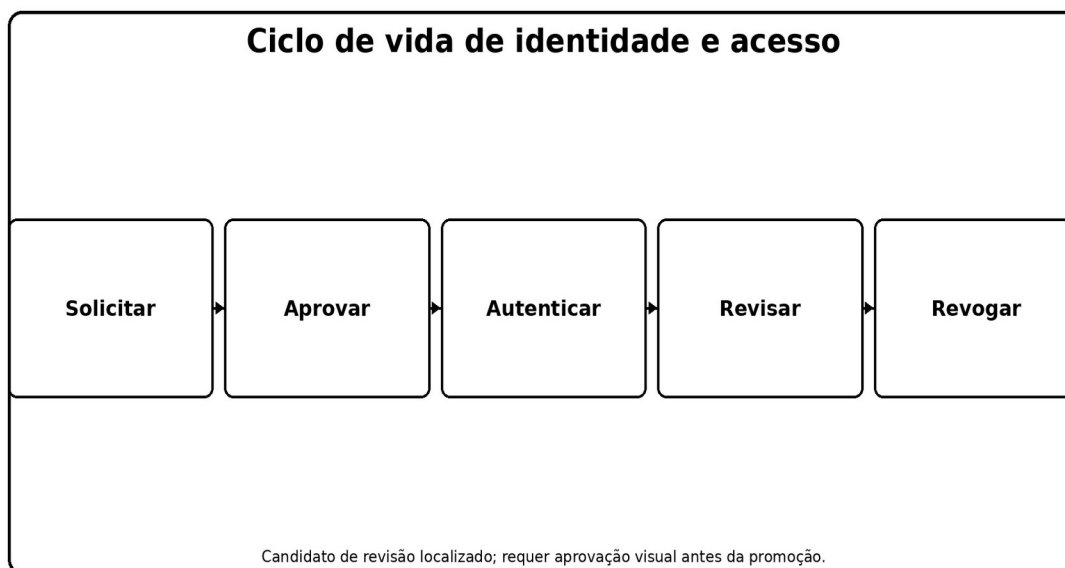
ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
5.1	Estabelecer e manter um	Manter uma população	Confirmar cobertura,	Inventários, diretórios,

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
	inventário de contas	completa de contas com responsável, tipo, estado e datas relevantes.	atualidade, responsáveis e conciliação.	relatórios e revisões.
5.2	Utilizar senhas exclusivas	Impedir a reutilização de senhas entre contas gerenciadas.	Revisar política, configuração, exceções e testes.	Política, configuração de identidade e resultados de auditoria.
5.3	Desabilitar contas inativas	Desabilitar oportunamente contas que ultrapassem o período de inatividade aprovado.	Confirmar limite, execução, exceções e acompanhamento.	Relatórios, tickets, registros e aprovações.
5.4	Restringir privilégios administrativos a contas administrativas dedicadas	Separar atividades administrativas das contas de uso normal.	Revisar população, privilégios, uso e exceções.	Diretórios, grupos privilegiados, PAM e registros de atividade.
5.5	Estabelecer e manter um inventário de contas de serviço	Manter responsável, finalidade, dependências, credenciais e revisão para cada conta de serviço.	Confirmar cobertura, rotação, uso e exceções.	Inventário, cofre de segredos, registros de rotação e revisões.
5.6	Centralizar a gestão de contas	Utilizar sistemas centrais de identidade para criar, alterar, desabilitar e revisar contas.	Verificar integrações, cobertura, processos e divergências.	Diretórios, IAM, fluxos de provisionamento e relatórios de conciliação.

Consulte os recursos oficiais do CIS para confirmar a linguagem e os critérios de avaliação.

11. Controle 6 — Gestão do controle de acesso

As 8 Salvaguardas, seu significado claro, o enfoque de verificação e exemplos de evidências.



Contas e privilégios exigem concessão aprovada, autenticação forte, revisão e revogação tempestiva.

Figura 6. Ciclo de vida de identidade e acesso

Finalidade do Controle: Fortalecer a organização por meio da implementação e medição das Salvaguardas de gestão do controle de acesso.

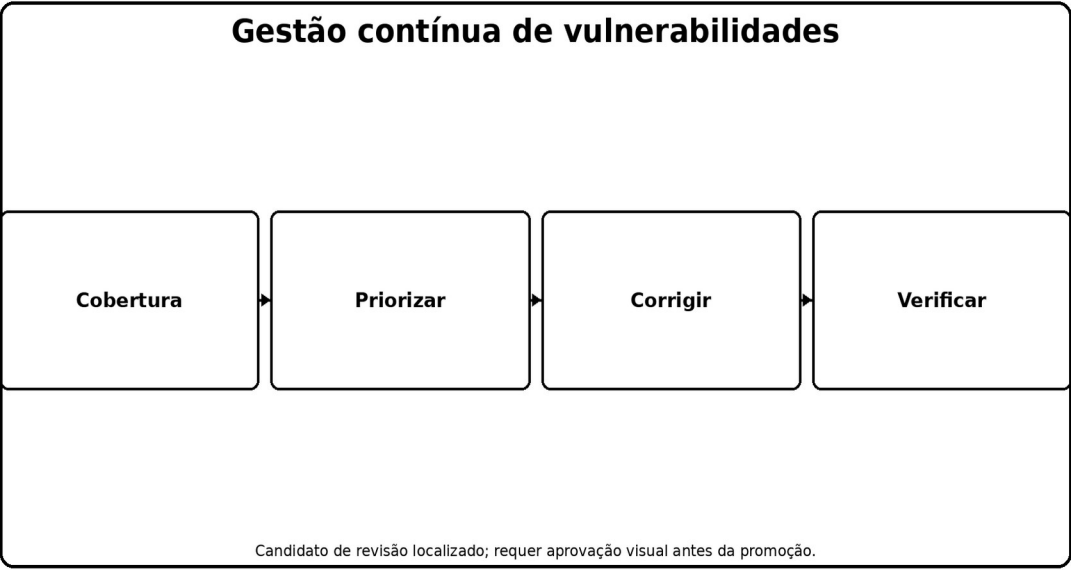
ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
6.1	Estabelecer um processo de concessão de acesso	Autorizar e provisionar acesso com base em necessidade, função e aprovação documentada.	Confirmar escopo, população, aprovadores, segregação de funções, prazo e exceções.	Solicitações, aprovações, registros de provisionamento, funções e revisões.
6.2	Estabelecer um processo de revogação de acesso	Remover ou ajustar acessos quando pessoas mudam de função, saem ou deixam de necessitar deles.	Verificar tempestividade, cobertura, integrações e exceções.	Tickets, registros de desligamento, relatórios de revogação e conciliações.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
6.3	Exigir MFA para aplicações expostas externamente	Proteger aplicações acessíveis pela internet com autenticação multifator.	Confirmar cobertura por aplicação, usuários, métodos permitidos e exceções.	Configurações de identidade, relatórios de MFA, inventário de aplicações e exceções.
6.4	Exigir MFA para acesso remoto à rede	Proteger VPN e outros métodos de acesso remoto com MFA.	Verificar cobertura, protocolos, grupos e exceções.	Configuração VPN, políticas de identidade, registros e testes.
6.5	Exigir MFA para acesso administrativo	Exigir MFA para contas e operações privilegiadas.	Confirmar população administrativa, plataformas cobertas e métodos resistentes a fraude quando aplicável.	PAM, diretórios, políticas, registros de autenticação e exceções.
6.6	Estabelecer e manter um inventário de sistemas de autenticação e autorização	Manter uma lista atualizada dos sistemas que autenticam usuários ou concedem permissões.	Verificar responsável, finalidade, integrações, criticidade e revisão.	Inventário, diagramas, responsáveis, integrações e revisões.
6.7	Centralizar o controle de acesso	Utilizar serviços centrais de identidade e autorização sempre que viável.	Confirmar cobertura, integrações, contas locais residuais e tratamento de divergências.	Diretórios, IAM, SSO, relatórios de integração e exceções.
6.8	Definir e manter controle de acesso baseado em funções	Associar permissões a funções aprovadas e revisar sua adequação.	Verificar catálogo de funções, proprietários, conflitos, revisões e exceções.	Matriz de funções, aprovações, recertificações e relatórios de conflito.

Consulte os recursos oficiais do CIS para confirmar a linguagem exata e os critérios de avaliação.

12. Controle 7 — Gestão contínua de vulnerabilidades

As 7 Salvaguardas, seu significado claro, o enfoque de verificação e exemplos de evidências.



Cobertura completa e remediação verificada importam mais do que apenas produzir relatórios de varredura.

Figura 7. Gestão contínua de vulnerabilidades

Finalidade do Controle: Fortalecer a organização por meio da implementação e medição das Salvaguardas de gestão contínua de vulnerabilidades.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
7.1	Estabelecer e manter um processo de gestão de vulnerabilidades	Definir escopo, responsáveis, fontes, frequência, priorização, correção e novos testes.	Confirmar cobertura, critérios, exceções e governança.	Política, procedimento, inventários, métricas e atas de revisão.
7.2	Estabelecer e manter um processo de	Priorizar e corrigir vulnerabilidades	Verificar SLAs, responsáveis, exceções,	Tickets, planos, exceções, aprovações e

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
	remediação	conforme risco e prazo aprovado.	compensações e escalonamento.	métricas.
7.3	Realizar gestão automatizada de correções do sistema operacional	Automatizar a distribuição e verificação de correções de sistemas operacionais.	Confirmar cobertura, anéis de teste, falhas, prazos e exceções.	Console de patch, relatórios, registros de mudança e tickets.
7.4	Realizar gestão automatizada de correções de aplicações	Automatizar a atualização de aplicações e componentes gerenciados.	Verificar inventário, cobertura, versões, falhas e exceções.	Ferramentas de gestão, relatórios, inventário e registros de mudança.
7.5	Executar varreduras automatizadas de vulnerabilidades em ativos internos	Avaliar periodicamente ativos internos, preferencialmente com autenticação.	Confirmar população, credenciais, frequência, exclusões e qualidade dos resultados.	Configurações de varredura, resultados, cobertura e exceções.
7.6	Executar varreduras automatizadas de vulnerabilidades em ativos expostos externamente	Avaliar ativos voltados à internet com frequência e escopo definidos.	Verificar inventário externo, cobertura, frequência, validação e exceções.	Inventário, resultados, relatórios de exposição e tickets.
7.7	Corrigir vulnerabilidades detectadas	Remediar ou tratar formalmente vulnerabilidades identificadas.	Confirmar prioridade, ação, prazo, evidência de correção e novo teste.	Tickets, alterações, exceções, rescans e evidências de encerramento.

Consulte os recursos oficiais do CIS para confirmar a linguagem exata e os critérios de avaliação.

13. Controle 8 — Gestão de registros de auditoria

As 12 Salvaguardas, seu significado claro, o enfoque de verificação e exemplos de evidências.

Finalidade do Controle: Fortalecer a organização por meio da implementação e medição das Salvaguardas de gestão de registros de auditoria.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
8.1	Estabelecer e manter um processo de gestão de registros de auditoria	Definir fontes, requisitos, responsáveis, proteção, retenção e revisão de logs.	Confirmar escopo, inventário, padrões, exceções e atualização.	Política, procedimento, inventário de fontes e registros de revisão.
8.2	Coletar registros de auditoria	Habilitar e coletar eventos necessários nos sistemas aplicáveis.	Verificar cobertura, tipos de evento, falhas de coleta e exceções.	Configurações, amostras de logs, relatórios de ingestão e alertas.
8.3	Garantir armazenamento adequado dos registros de auditoria	Dimensionar e proteger armazenamento para evitar perda ou alteração indevida.	Confirmar capacidade, integridade, acesso, monitoramento e exceções.	Configuração, métricas de capacidade, controles de acesso e alertas.
8.4	Padronizar a sincronização de tempo	Sincronizar relógios com fontes aprovadas para permitir correlação confiável.	Verificar fontes, cobertura, deriva, alertas e exceções.	Configuração NTP, inventário, métricas e registros.
8.5	Coletar registros detalhados de auditoria	Registrar detalhes suficientes para investigação e responsabilização.	Confirmar campos, identidade, ação, objeto, resultado, origem e horário.	Configurações, amostras de eventos e validações.
8.6	Coletar registros de consultas DNS	Registrar consultas DNS relevantes para detecção e investigação.	Verificar resolvedores cobertos, campos, retenção e ingestão.	Logs DNS, configuração, SIEM e relatórios de cobertura.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
8.7	Coletar registros de solicitações de URL	Registrar solicitações web relevantes em proxies, gateways ou serviços equivalentes.	Confirmar fontes, campos, privacidade, retenção e ingestão.	Logs de proxy, gateway, SIEM e testes.
8.8	Coletar registros de linha de comando	Registrar execução de comandos onde aplicável ao risco.	Verificar plataformas, usuários, integridade, privacidade e cobertura.	Políticas de auditoria, EDR, amostras de eventos e exceções.
8.9	Centralizar registros de auditoria	Enviar logs relevantes a uma plataforma central protegida.	Confirmar fontes, disponibilidade, atrasos, falhas e exceções.	SIEM, coletores, painéis de ingestão e alertas.
8.10	Reter registros de auditoria	Manter logs pelo período definido por risco e obrigações.	Verificar política, configuração, armazenamento e descarte.	Política de retenção, configurações, testes e relatórios.
8.11	Realizar revisões de registros de auditoria	Revisar eventos e alertas com frequência e responsabilidade definidas.	Confirmar casos de uso, responsáveis, frequência, escalonamento e evidências.	Procedimentos, tickets, investigações, métricas e atas.
8.12	Coletar registros de prestadores de serviços	Obter logs necessários de serviços terceirizados e em nuvem.	Verificar contratos, fontes, acesso, retenção, integração e lacunas.	Contratos, configurações de exportação, logs, SIEM e exceções.

Consulte os recursos oficiais do CIS para confirmar a linguagem exata e os critérios de avaliação.

14. Controle 9 — Proteções de e-mail e navegador web

As 7 Salvaguardas, seu significado claro, o enfoque de verificação e exemplos de evidências.

Finalidade do Controle: Fortalecer a organização por meio da implementação e medição das Salvaguardas de proteção de e-mail e navegador web.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
9.1	Garantir o uso apenas de navegadores e clientes de e-mail com suporte vigente	Permitir somente versões suportadas e atualizadas.	Confirmar inventário, versões, bloqueios, exceções e atualização.	Inventário, políticas, relatórios de versão e tickets.
9.2	Utilizar serviços de filtragem DNS	Bloquear domínios maliciosos ou não autorizados por meio de resolvedores aprovados.	Verificar cobertura, políticas, bypass, eventos e exceções.	Configuração DNS, políticas, logs e relatórios.
9.3	Manter e aplicar filtros de URL baseados em rede	Controlar acesso a categorias e destinos web conforme política.	Confirmar cobertura, regras, atualização, eventos e exceções.	Gateway web, proxy, políticas, logs e tickets.
9.4	Restringir extensões desnecessárias ou não autorizadas de navegadores e clientes de e-mail	Permitir somente extensões aprovadas e necessárias.	Verificar listas permitidas, aplicação, eventos e exceções.	GPO/MDM, catálogo aprovado, relatórios e tickets.
9.5	Implementar DMARC	Configurar SPF, DKIM e política DMARC apropriada para domínios de e-mail.	Confirmar cobertura de domínios, alinhamento, política, relatórios e exceções.	Registros DNS, relatórios DMARC, inventário de domínios e mudanças.
9.6	Bloquear tipos de arquivo desnecessários	Impedir anexos e downloads de tipos de arquivo não necessários ou de alto risco.	Verificar regras, cobertura, quarentena, eventos e exceções.	Políticas de gateway, registros, amostras e aprovações.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
9.7	Implantar e manter proteção antimalware em servidores de e-mail	Verificar mensagens e anexos com mecanismos atualizados.	Confirmar cobertura, atualização, detecção, quarentena e resposta.	Configuração, relatórios, alertas, tickets e métricas.

Consulte os recursos oficiais do CIS para confirmar a linguagem exata e os critérios de avaliação.

15. Controle 10 — Defesas contra malware

As 7 Salvaguardas, seu significado claro, o enfoque de verificação e exemplos de evidências.

Finalidade do Controle: Fortalecer a organização por meio da implementação e medição das Salvaguardas de defesa contra malware.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
10.1	Implantar e manter software antimalware	Proteger ativos aplicáveis com solução antimalware gerenciada.	Confirmar cobertura, estado, políticas, alertas e exceções.	Console, inventário, relatórios de cobertura e tickets.
10.2	Configurar atualizações automáticas de assinaturas antimalware	Atualizar automaticamente e mecanismos, assinaturas e inteligência.	Verificar frequência, falhas, cobertura e exceções.	Configuração, relatórios de atualização e alertas.
10.3	Desabilitar execução automática e reprodução automática em mídias removíveis	Impedir execução automática de conteúdo de mídias removíveis.	Confirmar política, plataformas, cobertura e exceções.	GPO/MDM, configuração, testes e relatórios.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
10.4	Configurar varredura antimalware automática de mídias removíveis	Verificar mídias removíveis antes ou durante o uso.	Confirmar política, eventos, bloqueios, cobertura e exceções.	Configuração, logs, alertas e testes.
10.5	Habilitar recursos antiexploração	Ativar proteções contra exploração de memória e comportamento malicioso.	Verificar plataformas, políticas, compatibilidade, eventos e exceções.	EDR, políticas, relatórios e testes.
10.6	Gerenciar software antimalware de forma centralizada	Administrar políticas, atualizações, alertas e resposta em console central.	Confirmar cobertura, acesso administrativo, monitoramento e exceções.	Console, funções, políticas, alertas e métricas.
10.7	Utilizar software antimalware baseado em comportamento	Detectar atividades suspeitas além de assinaturas conhecidas.	Verificar cobertura, regras, alertas, investigação e ajuste.	EDR, eventos, casos de investigação, tickets e métricas.

Consulte os recursos oficiais do CIS para confirmar a linguagem exata e os critérios de avaliação.

16. Controle 11 — Recuperação de dados

As 5 Salvaguardas, seu significado claro, o enfoque de verificação e exemplos de evidências.

Finalidade do Controle: Fortalecer a organização por meio da implementação e medição das Salvaguardas de recuperação de dados.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
11.1	Estabelecer e manter um processo de recuperação de dados	Definir responsabilidades, escopo, prioridades, dependências, objetivos e	Confirmar aprovação, responsáveis, cobertura, revisão e alinhamento	Política, plano de recuperação, inventário de sistemas, RTO/RPO, responsáveis e

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
		procedimentos para recuperar dados e serviços.	com necessidades de negócio.	registros de revisão.
11.2	Executar backups automatizados	Realizar cópias de segurança de dados e configurações conforme uma programação aprovada.	Verificar cobertura, frequência, falhas, alertas e tratamento de exceções.	Configuração de backup, relatórios de execução, alertas, tickets e métricas de sucesso.
11.3	Proteger os dados de recuperação	Proteger backups contra acesso, alteração, exclusão e criptografia não autorizados.	Revisar acesso, criptografia, imutabilidade, segregação e monitoramento.	ACLs, KMS, armazenamento imutável, registros de acesso e alertas.
11.4	Estabelecer e manter uma instância isolada de dados de recuperação	Manter pelo menos uma cópia de recuperação separada do ambiente de produção.	Confirmar isolamento lógico ou físico, credenciais separadas e resistência a ransomware.	Diagramas, configuração, inventário de cópias isoladas e testes de acesso.
11.5	Testar a recuperação de dados	Executar testes periódicos de restauração e confirmar integridade, tempo e completude.	Comparar resultados com critérios aprovados e verificar correções por novo teste.	Planos de teste, resultados de restauração, evidências de integridade, achados e retestes.

Consulte os recursos oficiais do CIS para confirmar a linguagem e os critérios de avaliação.

17. Controle 12 — Gestão da infraestrutura de rede

As 8 Salvaguardas, seu significado claro, o enfoque de verificação e exemplos de evidências.

Finalidade do Controle: Fortalecer a organização por meio da implementação e medição das Salvaguardas de gestão da infraestrutura de rede.

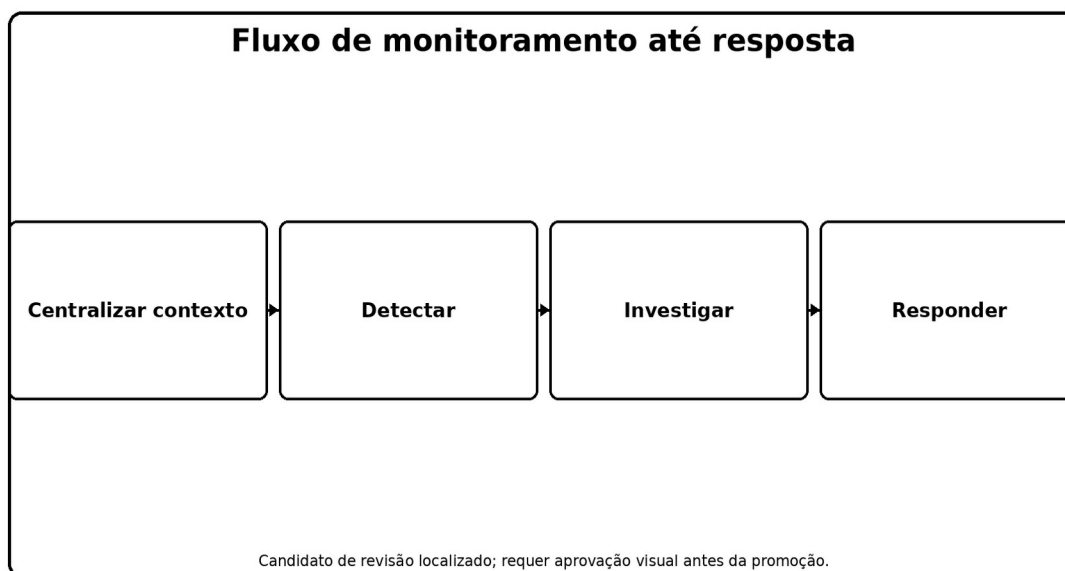
ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
12.1	Assegurar que a infraestrutura de rede esteja atualizada	Manter hardware, software e serviços de rede em versões suportadas e aprovadas.	Verificar inventário, versões, fim de suporte, exceções e planos de atualização.	Inventário, matrizes de suporte, configurações, tickets e exceções.
12.2	Estabelecer e manter uma arquitetura de rede segura	Definir zonas, fluxos, confiança, segmentação e controles de acesso conforme o risco.	Revisar arquitetura, aprovações, mudanças, fluxos permitidos e testes.	Diagramas, padrões, regras, análises de fluxo e resultados de testes.
12.3	Gerenciar com segurança a infraestrutura de rede	Utilizar canais, protocolos, autenticação e estações administrativas seguras.	Confirmar métodos administrativos, MFA, registros e restrições de origem.	Configuração, listas de administradores, bastions, PAM e registros.
12.4	Estabelecer e manter diagramas de arquitetura	Manter diagramas atuais da infraestrutura, conexões, zonas e dependências.	Verificar abrangência, responsáveis, revisão e conciliação com a configuração real.	Diagramas, CMDB, revisões e tickets de atualização.
12.5	Centralizar autenticação, autorização e auditoria de rede	Utilizar serviços centrais para identidade administrativa e registro de atividades.	Verificar cobertura, integrações, disponibilidade, contas locais e exceções.	RADIUS/TACACS+, diretórios, logs, inventário e exceções.
12.6	Utilizar protocolos seguros de gestão e comunicação de rede	Desabilitar protocolos inseguros e utilizar alternativas criptografadas e autenticadas.	Revisar configuração, cobertura, certificados e desvios.	Configurações SSH, HTTPS, SNMPv3, VPN, certificados e resultados de varredura.
12.7	Assegurar que dispositivos	Exigir canais seguros e	Confirmar cobertura, MFA,	Configuração VPN, AAA,

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
	remotos utilizem VPN e AAA corporativo	autenticação corporativa para acesso remoto à rede.	políticas, registros e exceções.	relatórios de conexão, políticas e tickets.
12.8	Manter recursos computacionais dedicados para trabalho administrativo	Separar atividades administrativas de navegação, e-mail e uso comum.	Verificar população, configuração, uso, monitoramento e exceções.	Inventário de estações administrativas, políticas, registros e controles de acesso.

Consulte os recursos oficiais do CIS para confirmar a linguagem e os critérios de avaliação.

18. Controle 13 — Monitoramento e defesa da rede

As 11 Salvaguardas, seu significado claro, o enfoque de verificação e exemplos de evidências.



Contexto centralizado, detecção ajustada, investigação humana e resposta formam uma defesa útil.

Figura 8. Fluxo de monitoramento até resposta

Finalidade do Controle: Fortalecer a organização por meio da implementação e medição das Salvaguardas de monitoramento e defesa da rede.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
13.1	Centralizar alertas de eventos de segurança	Reunir alertas relevantes em uma plataforma ou processo central de triagem.	Verificar fontes, cobertura, roteamento, prioridade e tratamento.	SIEM, integrações, filas, tickets, métricas e procedimentos.
13.2	Implantar uma solução de detecção de intrusão baseada em host	Detectar comportamento s e eventos suspeitos em endpoints e servidores.	Confirmar cobertura, estado dos agentes, regras, alertas e exceções.	Console EDR/HIDS, inventário, políticas, alertas e tickets.
13.3	Implantar uma solução de detecção de intrusão de rede	Monitorar tráfego de rede para identificar atividades suspeitas.	Verificar sensores, segmentos, regras, visibilidade e tratamento de alertas.	Configuração NIDS, diagramas, cobertura, eventos e investigações.
13.4	Realizar filtragem de tráfego entre segmentos de rede	Permitir somente fluxos necessários e aprovados entre zonas.	Revisar regras, justificativas, recertificação, mudanças e testes.	Regras de firewall, matrizes de fluxo, aprovações e resultados de testes.
13.5	Gerenciar o controle de acesso para ativos remotos	Aplicar identidade, postura, autorização e monitoramento ao acesso remoto.	Confirmar população, políticas, MFA, restrições e exceções.	VPN/ZTNA, MDM, IAM, registros e relatórios.
13.6	Coletar registros de fluxo de tráfego de rede	Manter telemetria suficiente para analisar comunicações e anomalias.	Verificar fontes, campos, retenção, sincronização e uso em investigações.	NetFlow/IPFIX, registros, retenção e casos de investigação.
13.7	Implantar uma solução de prevenção de	Bloquear ou conter atividades	Confirmar modo de prevenção, políticas,	Console HIPS/EDR, políticas,

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
	intrusão baseada em host	maliciosas em endpoints quando apropriado.	cobertura, exceções e testes.	eventos bloqueados e testes.
13.8	Implantar uma solução de prevenção de intrusão de rede	Bloquear tráfego malicioso conhecido conforme regras aprovadas.	Verificar posicionamento, modo, regras, exceções e impactos.	Configuração NIPS, alterações, eventos, exceções e testes.
13.9	Implantar controle de acesso em nível de porta	Controlar dispositivos e identidades que podem se conectar à rede.	Confirmar cobertura, autenticação, quarentena, exceções e falhas.	NAC/802.1X, inventário, políticas, registros e tickets.
13.10	Realizar filtragem na camada de aplicação	Restringir tráfego por aplicação, conteúdo ou contexto conforme o risco.	Revisar políticas, cobertura, exceções, alertas e mudanças.	Proxy, NGFW, WAF, regras, eventos e aprovações.
13.11	Ajustar limiares de alertas de eventos de segurança	Afinar regras para reduzir ruído sem perder detecções relevantes.	Confirmar responsáveis, critérios, histórico, testes e revisão periódica.	Registros de tuning, métricas, casos de teste e aprovações.

Consulte os recursos oficiais do CIS para confirmar a linguagem e os critérios de avaliação.

19. Controle 14 — Conscientização e capacitação em segurança

As 9 Salvaguardas, seu significado claro, o enfoque de verificação e exemplos de evidências.

Finalidade do Controle: Fortalecer a organização por meio da implementação e medição das Salvaguardas de conscientização e capacitação em segurança.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
14.1	Estabelecer e	Definir	Verificar	Programa,

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
	manter um programa de conscientização em segurança	conteúdo, público, frequência, responsabilidades, avaliação e melhoria.	aprovação, cobertura, atualidade, conclusão e exceções.	currículo, população, registros de conclusão e métricas.
14.2	Capacitar a força de trabalho para reconhecer ataques de engenharia social	Ensinar identificação e comunicação de phishing, fraude, pretexting e manipulação.	Confirmar conteúdo, frequência, simulações, resultados e acompanhamento.	Materiais, simulações, relatórios, tickets e ações corretivas.
14.3	Capacitar a força de trabalho em boas práticas de autenticação	Ensinar uso de MFA, senhas exclusivas, gestores de senhas e proteção de credenciais.	Verificar conteúdo, população, conclusão e avaliação.	Treinamento, registros, avaliações e campanhas.
14.4	Capacitar a força de trabalho em boas práticas de tratamento de dados	Ensinar classificação, compartilhamento, armazenamento, retenção e descarte seguros.	Confirmar alinhamento com políticas e cobertura de funções relevantes.	Materiais, políticas, registros de conclusão e avaliações.
14.5	Capacitar a força de trabalho sobre causas de exposição não intencional de dados	Explicar erros comuns, destinatários incorretos, links públicos, dispositivos e serviços não aprovados.	Verificar exemplos, público, conclusão e resultados.	Conteúdo, campanhas, registros e incidentes correlacionados.
14.6	Capacitar a força de trabalho para reconhecer e comunicar incidentes de segurança	Ensinar sinais, canais, urgência e informações necessárias para reporte.	Confirmar canais, exercícios, conhecimento e acompanhamento.	Materiais, contatos, exercícios, tickets e métricas de reporte.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
14.7	Capacitar a força de trabalho para identificar e comunicar atualizações de segurança ausentes	Ensinar como reconhecer sistemas desatualizados e reportar desvios.	Verificar conteúdo, população e integração com suporte.	Treinamento, procedimentos, tickets e exemplos.
14.8	Capacitar a força de trabalho sobre riscos de redes inseguras	Ensinar uso seguro de Wi-Fi, VPN, hotspots e redes públicas.	Confirmar cobertura de trabalhadores remotos e viajantes.	Materiais, políticas, registros e avaliações.
14.9	Conduzir conscientização e capacitação específicas por função	Fornecer treinamento adicional para funções com riscos ou privilégios específicos.	Verificar matriz de funções, conteúdo, conclusão, competência e atualização.	Matriz, cursos, avaliações, certificações internas e registros.

Consulte os recursos oficiais do CIS para confirmar a linguagem e os critérios de avaliação.

20. Controle 15 — Gestão de prestadores de serviços

As 7 Salvaguardas, seu significado claro, o enfoque de verificação e exemplos de evidências.

Finalidade do Controle: Fortalecer a organização por meio da implementação e medição das Salvaguardas de gestão de prestadores de serviços.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
15.1	Estabelecer e manter um inventário de prestadores de serviços	Manter uma população completa de terceiros com responsável, serviço, criticidade, dados, acesso e vigência.	Confirmar cobertura, atualização, responsáveis e conciliação.	Inventário, contratos, classificações e registros de revisão.
15.2	Estabelecer e manter uma	Definir requisitos de	Verificar aprovação,	Política, procedimentos,

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
	política de gestão de prestadores de serviços	seleção, contratação, monitoramento, incidentes e encerramento.	escopo, revisão e aplicação.	aprovações e registros.
15.3	Classificar prestadores de serviços	Priorizar terceiros conforme criticidade, acesso, dados e impacto.	Confirmar critérios, responsáveis e atualização.	Matriz de classificação, avaliações e aprovações.
15.4	Assegurar que contratos incluam requisitos de segurança	Incorporar obrigações de controle, evidência, incidentes, subcontratados e saída.	Revisar cláusulas, exceções e cobertura contratual.	Contratos, aditivos, modelos e aprovações.
15.5	Avaliar prestadores de serviços	Executar avaliações proporcionais ao risco antes e durante a relação.	Confirmar escopo, frequência, achados e correção.	Questionários, relatórios, evidências e planos de ação.
15.6	Monitorar prestadores de serviços	Acompanhar mudanças, desempenho de controles, incidentes e riscos.	Verificar métricas, alertas, revisões e escalonamento.	Painéis, atas, alertas e tickets.
15.7	Encerrar prestadores de serviços com segurança	Remover acessos, devolver ou eliminar dados e confirmar obrigações de saída.	Confirmar checklist, responsáveis, evidência e encerramento.	Registros de revogação, certificados, tickets e aceite final.

Consulte os recursos oficiais do CIS para confirmar a linguagem e os critérios de avaliação.

21. Controle 16 — Segurança de software de aplicação

As 14 Salvaguardas, seu significado claro, o enfoque de verificação e exemplos de evidências.

Finalidade do Controle: Fortalecer a organização por meio da implementação e medição das Salvaguardas de segurança de software de aplicação.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
16.1	Estabelecer e manter um processo seguro de desenvolvimento de aplicações	Integrar segurança ao ciclo de vida de desenvolvimento.	Confirmar escopo, responsáveis, etapas, exceções e revisão.	SDLC, padrões, gates e registros.
16.2	Estabelecer e manter um processo para receber e tratar vulnerabilidades de software	Receber, avaliar, corrigir e comunicar vulnerabilidades reportadas.	Verificar canal, triagem, prazos e encerramento.	Política de divulgação, tickets e comunicações.
16.3	Realizar análise de causa raiz de vulnerabilidades	Identificar causas sistêmicas e evitar recorrência.	Confirmar método, ações e verificação posterior.	Relatórios, ações corretivas e novos testes.
16.4	Estabelecer e gerenciar um inventário de componentes de software de terceiros	Manter componentes, versões, origem, licença e estado de suporte.	Confirmar cobertura, atualização e conciliação.	SBOM, inventários e relatórios de dependências.
16.5	Utilizar componentes de terceiros atualizados e confiáveis	Restringir componentes obsoletos, inseguros ou não confiáveis.	Verificar origem, suporte, vulnerabilidades e exceções.	Políticas, registros de versão e aprovações.
16.6	Estabelecer um sistema de classificação de severidade e processo para vulnerabilidades	Priorizar achados de aplicação de modo consistente.	Confirmar critérios, SLAs, exceções e escalonamento.	Matriz, tickets e métricas.
16.7	Utilizar modelos	Aplicar	Revisar padrões,	Baselines, IaC,

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
	padronizados de endurecimento para infraestrutura de aplicação	configurações seguras e repetíveis.	cobertura, desvios e correções.	avaliações e exceções.
16.8	Separar sistemas de produção e não produção	Isolar ambientes, dados, acessos e credenciais.	Confirmar arquitetura, permissões e fluxos.	Diagramas, regras, inventários e testes.
16.9	Capacitar desenvolvedores em segurança de aplicações e codificação segura	Treinar conforme função, tecnologia e risco.	Verificar população, conteúdo, conclusão e eficácia.	Currículo, presença e avaliações.
16.10	Aplicar princípios de projeto seguro em arquiteturas de aplicações	Incorporar redução de superfície, privilégio mínimo e defesa em profundidade.	Revisar decisões, modelos e exceções.	Registros de arquitetura, checklists e aprovações.
16.11	Utilizar módulos ou serviços avaliados para componentes de segurança	Preferir componentes confiáveis para autenticação, criptografia e funções críticas.	Confirmar seleção, configuração e atualização.	Catálogo aprovado, revisões e testes.
16.12	Implementar verificações de segurança em nível de código	Executar análise estática, revisão e outros controles adequados.	Confirmar cobertura, regras, achados e correção.	Resultados SAST, revisões e tickets.
16.13	Realizar testes de penetração de aplicações	Testar aplicações autorizadas com escopo e metodologia definidos.	Verificar autorização, cobertura, achados e reteste.	Regras de engajamento, relatórios e evidências.
16.14	Realizar modelagem de ameaças	Identificar ativos, fronteiras,	Confirmar escopo, participantes,	Modelos, atas, diagramas e ações.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
		ameaças e controles antes da liberação.	decisões e atualização.	

Consulte os recursos oficiais do CIS para confirmar a linguagem e os critérios de avaliação.

22. Controle 17 — Gestão de resposta a incidentes

As 9 Salvaguardas, seu significado claro, o enfoque de verificação e exemplos de evidências.



Papéis, comunicação, exercícios e revisões mantêm a resposta a incidentes preparada.

Figura 9. Preparação para resposta a incidentes

Finalidade do Controle: Fortalecer a organização por meio da implementação e medição das Salvaguardas de gestão de resposta a incidentes.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
17.1	Designar pessoal para gerenciar o tratamento de incidentes	Definir responsáveis primários e substitutos.	Confirmar nomes, autoridade, disponibilidade e revisão.	Matriz de funções, escalas e aprovações.
17.2	Manter	Disponibilizar	Verificar	Listas, páginas

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
	informações de contato para relatar incidentes	canais internos e externos atualizados.	publicação, teste e atualização.	internas e registros de teste.
17.3	Estabelecer e manter um processo empresarial para relatar incidentes	Definir como trabalhadores e terceiros reconhecem e comunicam eventos.	Confirmar clareza, treinamento e rastreabilidade.	Procedimentos, tickets e registros de treinamento.
17.4	Estabelecer e manter um processo de resposta a incidentes	Documentar preparação, análise, contenção, erradicação, recuperação e revisão.	Revisar escopo, papéis, gatilhos e atualização.	Plano, playbooks e aprovações.
17.5	Atribuir funções e responsabilidades principais	Definir responsabilidades técnicas, jurídicas, executivas e de comunicação.	Confirmar cobertura, autoridade e substituição.	RACI, contatos e exercícios.
17.6	Definir mecanismos de comunicação durante a resposta	Estabelecer canais seguros, internos e externos.	Verificar alternativas, autorização e testes.	Planos, listas, ferramentas e registros.
17.7	Realizar exercícios rotineiros de resposta a incidentes	Testar planos e equipes com cenários apropriados.	Confirmar frequência, participantes, resultados e ações.	Roteiros, atas, achados e planos de ação.
17.8	Realizar revisões pós-incidente	Registrar lições, causas e melhorias após incidentes.	Verificar conclusão, responsáveis e acompanhamento.	Relatórios, ações e evidências de fechamento.
17.9	Estabelecer e manter limites de incidentes de segurança	Definir quando eventos se tornam incidentes e	Confirmar critérios, aprovação e aplicação.	Matriz de severidade, playbooks e tickets.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
		exigem escalonamento.		

Consulte os recursos oficiais do CIS para confirmar a linguagem e os critérios de avaliação.

23. Controle 18 — Testes de penetração

As 5 Salvaguardas, seu significado claro, o enfoque de verificação e exemplos de evidências.

Finalidade do Controle: Fortalecer a organização por meio da implementação e medição das Salvaguardas de testes de penetração.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
18.1	Estabelecer e manter um programa de testes de penetração	Definir escopo, frequência, independência, autorização e acompanhamento.	Confirmar governança, cobertura e atualização.	Programa, regras de engajamento e cronograma.
18.2	Realizar testes externos periódicos	Avaliar ativos e caminhos externos autorizados.	Verificar escopo, metodologia, qualificação e achados.	Relatórios, evidências e planos de ação.
18.3	Corrigir achados de testes de penetração	Priorizar, corrigir e acompanhar resultados.	Confirmar responsáveis, prazos, exceções e reteste.	Tickets, aprovações e resultados de reteste.
18.4	Validar medidas de segurança	Verificar se controles resistem às técnicas testadas.	Relacionar cenários, controles, resultados e limitações.	Matriz de validação, relatórios e evidências.
18.5	Realizar testes internos periódicos	Avaliar caminhos internos autorizados e movimento lateral.	Confirmar escopo, segurança operacional e reteste.	Regras de engajamento, relatórios e ações.

Consulte os recursos oficiais do CIS para confirmar a linguagem e os critérios de avaliação.

24. Ferramentas de código aberto

Links oficiais, inícios seguros, evidências e limitações.

Ferramenta	Finalidade	Controles que pode apoiar
CIS Controls Navigator	Selecionar Grupos de Implementação e consultar mapeamentos oficiais.	Todos
CIS Controls Assessment Specification	Aplicar a orientação oficial de medição.	Todos
CIS-CAT Lite	Avaliar configurações de benchmarks CIS disponíveis.	4, 7
CISO Assistant	Gerenciar controles, riscos, evidências e achados.	Todos
Wazuh	Monitoramento de endpoints, SIEM, FIM e alertas.	1, 4, 8, 10, 13, 17
osquery	Consultar ativos, software, contas e configurações.	1, 2, 4, 5, 8
OpenSCAP	Avaliar configurações seguras em Linux.	4, 7
Lynis	Auditar segurança de sistemas Linux.	4, 7
Nmap	Descobrir ativos e serviços autorizados.	1, 2, 12
Greenbone Community Edition	Avaliar vulnerabilidades.	7
Trivy	Analisar repositórios, imagens, dependências, segredos e IaC.	2, 7, 16
OWASP ZAP	Testar aplicações web autorizadas.	16, 18
Suricata	Detectar intrusões e observar tráfego de rede.	13
Keycloak	Gerenciar identidade, funções, MFA, sessões e eventos.	5, 6, 8
DefectDojo	Gerenciar achados, deduplicação, correção e reteste.	7, 16, 18
Velociraptor	Obter visibilidade de endpoints e apoiar resposta a	1, 8, 13, 17

Ferramenta	Finalidade	Controles que pode apoiar
	incidentes.	

Limitação crítica: Uma ferramenta pode apoiar Salvaguardas, mas não escolhe o Grupo de Implementação, não define tolerância ao risco, não garante cobertura completa, não substitui procedimentos ou revisão humana e não comprova conformidade por si só.

24.1 CIS Controls Navigator

Projeto oficial: <https://www.cisecurity.org/controls/cis-controls-navigator>

Use a versão 8.1, selecione o Grupo de Implementação e os mapeamentos necessários e preserve a configuração exportada como evidência.

24.2 CIS Controls Assessment Specification

Documentação oficial: <https://cas.docs.cisecurity.org/en/latest/>

Identifique entradas, premissas, operações, medidas, métricas e revisão de procedimentos para cada Salvaguarda avaliada.

24.3 CIS-CAT Lite

Projeto oficial: <https://learn.cisecurity.org/cis-cat-lite>

Execute somente em sistemas autorizados, preserve o relatório, valide achados, corrija e reavalie.

24.4 CISO Assistant

Projeto oficial: <https://intuitem.github.io/ciso-assistant-community/>

Crie um projeto com escopo definido, atribua responsáveis, anexe evidências e acompanhe achados e ações.

24.5 Wazuh

Projeto oficial: <https://wazuh.com/>

Inscreva endpoints autorizados, gere eventos seguros de teste, confirme coleta e alertas e preserve evidências de cobertura e resposta.

24.6 osquery

Projeto oficial: <https://www.osquery.io/>

Execute consultas somente leitura em laboratório ou ambiente autorizado e compare resultados com inventários aprovados.

24.7 OpenSCAP

Projeto oficial: <https://www.open-scap.org/>

Selecione um perfil apropriado, avalie sistemas autorizados, valide resultados, documente exceções e repita a avaliação.

24.8 Lynis

Projeto oficial: <https://cisofy.com/lynis/>

Audite hosts autorizados, compare os resultados com padrões aprovados e documente correções e novos testes.

24.9 Nmap

Projeto oficial: <https://nmap.org/>

Utilize varreduras limitadas a intervalos autorizados por escrito e preserve escopo, comandos, resultados e conciliação.

24.10 Greenbone Community Edition

Projeto oficial: <https://greenbone.github.io/docs/latest/>

Atualize feeds, utilize alvos autorizados, valide cobertura, corrija achados e execute nova varredura.

24.11 Trivy

Projeto oficial: <https://trivy.dev/>

Analise repositórios ou imagens autorizados, valide achados, documente exceções e repita a análise após correções.

24.12 OWASP ZAP

Projeto oficial: <https://www.zaproxy.org/>

Utilize aplicações de treinamento ou aplicações autorizadas; execute testes ativos somente com aprovação explícita.

24.13 Suricata

Projeto oficial: <https://suricata.io/>

Use sensores autorizados, valide interfaces e regras, gere tráfego de teste aprovado e ajuste alertas com controle de mudanças.

24.14 Keycloak

Projeto oficial: <https://www.keycloak.org/>

Configure um ambiente de laboratório, funções, MFA e eventos e teste cenários de entrada, mudança e saída de usuários.

24.15 DefectDojo

Projeto oficial: <https://www.defectdojo.org/>

Importe resultados autorizados, valide deduplicação, atribua responsáveis e encerre achados somente após reteste confirmado.

24.16 Velociraptor

Projeto oficial: <https://docs.velociraptor.app/>

Utilize apenas ambientes autorizados, limite a coleta ao necessário e proteja os dados obtidos.

25. Guia dos CIS Controls para gestores

Perguntas, indicadores, responsabilidades e decisões que gestores devem controlar.

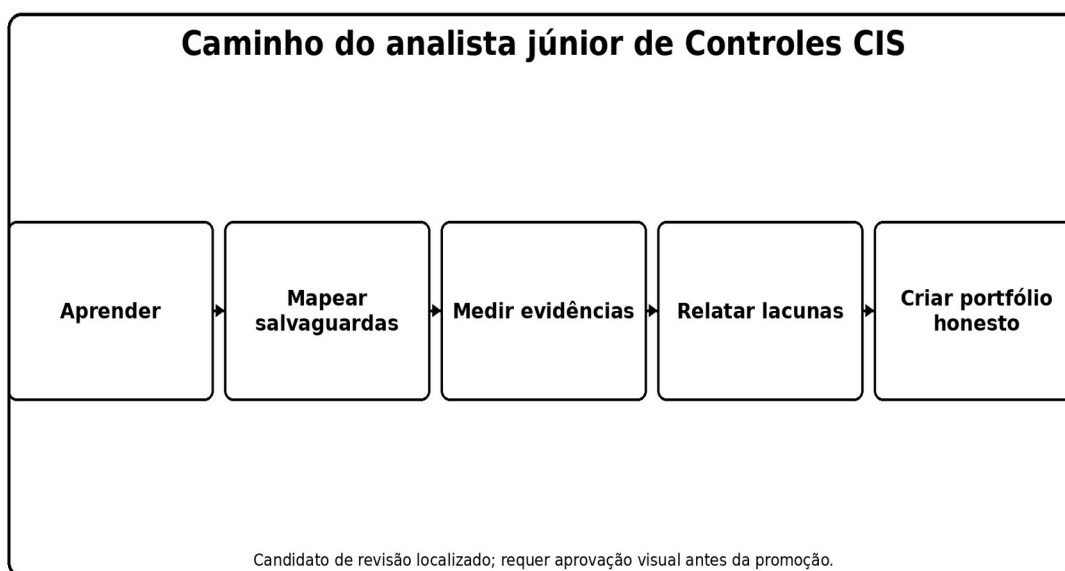
1. O Grupo de Implementação selecionado continua adequado ao risco, aos dados, aos serviços e às obrigações?
2. Os inventários essenciais são completos, atuais, atribuídos e conciliados?
3. Quais Salvaguardas apresentam cobertura incompleta, revisão atrasada ou dados não confiáveis?
4. A exposição de acessos privilegiados, ativos externos, software sem suporte e falhas de recuperação aumentou?
5. Alertas resultam em investigação e resposta ou apenas em volume de painel?
6. Responsabilidades de prestadores, incidentes, subcontratados e saída estão claras?
7. Testes e exercícios são autorizados, adequadamente definidos e acompanhados até o reteste?
8. Quais decisões de orçamento, pessoal ou prioridade bloqueiam a correção?

Área	Pergunta de gestão	Estado sugerido
Grupo e escopo	Priorização, acréscimos, exclusões e obrigações estão documentados?	Verde, amarelo ou vermelho
Inventários	Ativos, software, dados, contas, fornecedores, aplicações e registros estão completos?	Verde, amarelo ou vermelho
Proteção	Configuração, acesso, correções, e-mail, malware e proteção de dados funcionam?	Verde, amarelo ou vermelho
Deteção	Cobertura de registros e rede	Verde, amarelo ou vermelho

Área	Pergunta de gestão	Estado sugerido
	é suficiente e alertas são analisados?	
Recuperação	Backups estão protegidos e restaurações são testadas?	Verde, amarelo ou vermelho
Resposta	Papéis, contatos, limiares, exercícios e revisões estão atualizados?	Verde, amarelo ou vermelho
Medição	Entradas são confiáveis e exceções são corrigidas?	Verde, amarelo ou vermelho
Garantia	Testes, limitações, resultados e retestes são defensáveis?	Verde, amarelo ou vermelho

26. Guia profissional para analistas juniores

Uma rota prática para funções de controles, vulnerabilidades, garantia, GRC e operações de segurança.



Aprender a estrutura, mapear Salvaguardas, medir evidências, relatar lacunas e construir um portfólio honesto.

Figura 10. Caminho profissional para analistas juniores de CIS Controls

Funções comuns incluem analista júnior de controles de segurança, analista de GRC, analista de gestão de vulnerabilidades, analista de garantia de segurança, analista de operações de segurança, analista de conformidade de TI, analista de risco de terceiros e analista de programa de cibersegurança.

26.1 Trabalho júnior típico

- Manter inventários de ativos, software, dados, contas, redes, fornecedores, aplicações, achados e evidências.
- Coletar evidências sem alterar registros de origem e validar a completude da população.
- Relacionar Salvaguardas a responsáveis, sistemas, procedimentos, configurações, métricas, exceções e ações.
- Executar ferramentas autorizadas sob procedimentos aprovados.
- Calcular métricas de cobertura e exceção utilizando a estrutura oficial de avaliação.
- Acompanhar achados até a correção e o reteste.
- Escrever conclusões claras sem exceder o suporte das evidências.

Competência	Evidência de portfólio
Estrutura	Explicar os 18 Controles, Grupos de Implementação, classes de ativos e funções.
Inventário	Conciliar duas fontes independentes e explicar diferenças.
Medição	Demonstrar entradas, operações, medidas, métrica, exceções e conclusão.
Alfabetização técnica	Interpretar configuração, identidade, varredura, registros, recuperação e evidências de aplicação.
Correção	Acompanhar responsável, prazo, correção e reteste verificado.
Comunicação	Produzir resumo executivo e papel de trabalho detalhado.
Ética	Utilizar dados sintéticos, autorização, limites de escopo e alegações honestas.

27. Laboratório fictício e portfólio

Um exercício autorizado para demonstrar inventário, medição, correção e reteste sem expor dados reais.

27.1 Cenário

Crie uma organização fictícia de 50 pessoas com laptops, servidores, serviços em nuvem, uma aplicação web, trabalho remoto e cinco prestadores de serviços. Use somente dados sintéticos, ativos de laboratório e sistemas para os quais exista autorização explícita.

27.2 Etapas do laboratório

1. Seleccione o IG1 e documente três acréscimos baseados em risco provenientes do IG2 ou IG3.

2. Construa inventários de ativos empresariais, software, dados, contas, sistemas de autenticação, redes, prestadores de serviços, aplicações e fontes de logs.
3. Utilize Nmap e osquery em um ambiente isolado para reconciliar inventários de ativos e software.
4. Utilize OpenSCAP ou Lynis em um host de laboratório e registre achados de configuração, exceções, correções e nova avaliação.
5. Utilize Greenbone em alvos aprovados; valide cobertura, achados, remediação e nova varredura.
6. Utilize Wazuh ou Suricata para gerar e investigar um alerta de teste seguro.
7. Utilize Trivy ou ZAP em um repositório de treinamento ou aplicação de laboratório; registre correção e reteste.
8. Execute um teste documentado de restauração de backup e um exercício de mesa de resposta a incidentes.
9. Crie cinco papéis de trabalho alinhados à CIS Controls Assessment Specification, incluindo entradas, operações, medidas, métricas, exceções e conclusões.
10. Publique somente artefatos higienizados e declare claramente que o projeto é fictício e não constitui uma avaliação formal do CIS.

27.3 Artefatos de portfólio

Artefato	Evidência demonstrada
Memorando de seleção do IG	Priorização, contexto e raciocínio de risco.
Inventários reconciliados	Compleitude, propriedade, fonte, data e exceções.
Papel de trabalho de Salvaguarda	Estrutura oficial de medição e conclusão sustentada.
Registro de achados	Severidade, responsável, prazo, correção e reteste.
Relatório de exercício	Cenário, decisões, lacunas e ações de melhoria.
Resumo executivo	Risco, cobertura, limitações e decisões necessárias.

28. Plano de aprendizagem de trinta dias

Uma sequência prática para compreender a estrutura, produzir evidências e explicar resultados.

Dias	Foco	Entregável
1–4	Estrutura dos 18 Controles, 153 Salvaguardas, IGs, classes de ativos e funções de segurança.	Mapa de conceitos e seleção preliminar de IG.
5–8	Inventários, escopo,	Inventários sintéticos e

Dias	Foco	Entregável
	responsáveis, exceções e dependências.	matriz RACI.
9–12	Configurações seguras, vulnerabilidades, identidades e proteção de dados.	Dois papéis de trabalho e um registro de achados.
13–16	Logs, monitoramento, malware, e-mail e segurança de rede.	Caso de alerta investigado e evidências de cobertura.
17–20	Backup, resposta a incidentes, prestadores e desenvolvimento seguro.	Teste de restauração e exercício de mesa.
21–24	CIS Controls Assessment Specification.	Cinco avaliações de Salvaguardas com medidas e métricas.
25–27	Correção, reteste, relatórios e comunicação executiva.	Plano de ação e resumo executivo.
28–30	Revisão técnica, portfólio e preparação para entrevistas.	Portfólio higienizado e respostas praticadas.

29. Preparação para entrevistas

29.1 Como explicar os CIS Controls

Os CIS Controls são um conjunto priorizado de boas práticas de cibersegurança organizado em 18 Controles e 153 Salvaguardas. Eles ajudam a transformar objetivos defensivos em ações atribuíveis e mensuráveis, priorizadas pelos Grupos de Implementação.

29.2 O que é o IG1?

O IG1 contém 56 Salvaguardas e representa a higiene cibernética essencial. É o ponto de partida recomendado, mas a organização deve acrescentar Salvaguardas quando risco, obrigações, dados, serviços ou ameaças exigirem proteção adicional.

29.3 O IG1 atende a todos os requisitos?

Não. Um Grupo de Implementação é um mecanismo de priorização, não uma autorização para ignorar leis, contratos, requisitos setoriais ou riscos materiais.

29.4 Como medir uma Salvaguarda?

Defina a população aplicável, valide as entradas, execute operações repetíveis, produza medidas, calcule métricas, examine exceções e revise o procedimento. Preserve a evidência que sustenta a conclusão.

29.5 Qual é a diferença entre ferramenta e controle?

Uma ferramenta pode apoiar uma Salvaguarda, mas não substitui escopo, processo, responsáveis, configuração, tratamento de exceções, medição, revisão humana ou melhoria contínua.

29.6 Como tratar uma exceção?

Documente o ativo ou população afetada, justificativa, risco, controles compensatórios, responsável, aprovação, prazo e critério de revisão. Exceções não devem desaparecer dentro de uma porcentagem agregada.

29.7 Como apresentar um achado?

Explique o critério, a condição observada, a população afetada, o risco, a causa provável, a recomendação, o responsável, o prazo e o método de reteste.

29.8 Como evitar alegações excessivas?

Diferencie implementação, desenho, operação, teste e conformidade. Declare escopo, período, limitações, fontes e dependências. Um mapeamento ou uma ferramenta não comprova automaticamente conformidade.

29.9 Perguntas para fazer ao empregador

- Qual Grupo de Implementação foi selecionado e como a decisão é revista?
- Quais inventários são fontes oficiais e como a completude é conciliada?
- Como as exceções são aprovadas, monitoradas e encerradas?
- Quais Salvaguardas apresentam maior exposição residual?
- Como são realizados retestes e exercícios de recuperação?
- Como prestadores de serviços fornecem evidências e notificam incidentes?

30. Modelos, glossário, índice e referências

30.1 Modelo de papel de trabalho

Campo	Conteúdo esperado
Salvaguarda	Número, título, IG, classe de ativo e função de segurança.
Escopo	Sistemas, unidades, locais, contas, dados e período.
Critério	Texto oficial e procedimento de avaliação aplicável.
Entradas	Populações, fontes, responsáveis, datas e validações.
Operações	Etapas executadas para produzir medidas.

Campo	Conteúdo esperado
Medidas e métricas	Contagens, listas, cobertura, exceções e interpretação.
Evidências	Arquivos, consultas, capturas, registros e aprovações.
Conclusão	Implementada, parcialmente implementada ou não implementada, com limitações.
Ações	Responsável, prioridade, prazo, correção e reteste.

30.2 Registro de achados e retestes

ID	Salvaguarda	Condição	Risco	Responsável	Prazo	Estado	Evidência de reteste
EX-001	7.7	Exemplo sintético de vulnerabilidade fora do prazo.	Exposição elevada.	Responsável fictício.	AAAA-MM-DD	Aberto	Pendente.

30.3 Glossário

Termo	Definição prática
Classe de ativo	Categoria afetada por uma Salvaguarda, como dispositivos, software, dados, redes, usuários ou documentação.
CIS Benchmark	Recomendações de configuração segura para uma tecnologia específica.
Controle CIS	Uma das 18 áreas amplas de defesa.
Salvaguarda CIS	Ação específica e implementável dentro de um Controle.
Cobertura	Parte da população aplicável na qual a Salvaguarda está adequadamente implementada.
IG1	Conjunto de 56 Salvaguardas de higiene cibernética essencial.
IG2	IG1 acrescido de 74 Salvaguardas para maior complexidade e risco.
IG3	Todas as 153 Salvaguardas, incluindo 23 adicionais para ambientes de maior risco.
Medida	Contagem, lista, data, configuração ou resultado produzido pelas operações de

Termo	Definição prática
Métrica	avaliação. Cálculo ou interpretação derivada de uma ou mais medidas.
Revisão de procedimento	Avaliação manual da existência e suficiência de um processo documentado.
Reteste	Nova avaliação realizada após a correção, utilizando critérios comparáveis e uma população atualizada.

30.4 Índice de assuntos

- Avaliação e medição: capítulos 4 e 30.
- Configurações seguras: Controles 4 e 16.
- Dados: Controle 3.
- Evidências e métricas: capítulos 4, 27 e 30.
- Grupos de Implementação: capítulo 2.
- Identidades e acessos: Controles 5 e 6.
- Inventários: Controles 1, 2, 3, 5, 12 e 15.
- Monitoramento e logs: Controles 8 e 13.
- Prestadores de serviços: Controle 15.
- Recuperação e incidentes: Controles 11 e 17.
- Vulnerabilidades: Controle 7.

30.5 Referências oficiais

- CIS Controls v8.1: <https://www.cisecurity.org/controls/v8-1>
- Lista dos CIS Controls: <https://www.cisecurity.org/controls/cis-controls-list>
- Grupos de Implementação: <https://www.cisecurity.org/controls/implementation-groups>
- CIS Controls Assessment Specification: <https://www.cisecurity.org/controls/cis-controls-assessment-specification>

Lembrete final: Estruturas, mapeamentos, ferramentas, produtos, ameaças, leis, contratos e riscos organizacionais mudam. Confirme sempre os recursos oficiais atuais e as obrigações aplicáveis antes de implementar, avaliar ou publicar conclusões.